

MedTech Security Baseline Checker

Cloud Security Engineer

Cloud Security Capstone · Option A

Five AWS controls. Reproducible evidence. Explicit limits.

Charlotte Zhang and Nana Ge

PROBLEM STATEMENT

Cloud configuration changes need repeatable security review

Self-service AI infrastructure

AI teams create training buckets, identities and compute resources as their workloads evolve.

Configuration gaps create risk

Weak access controls can expose sensitive data. A finding needs evidence and contextual review.

Manual review needs support

Repeatable checks give reviewers consistent evidence, explicit scope and actionable next steps.

AUTOMATION OPPORTUNITY

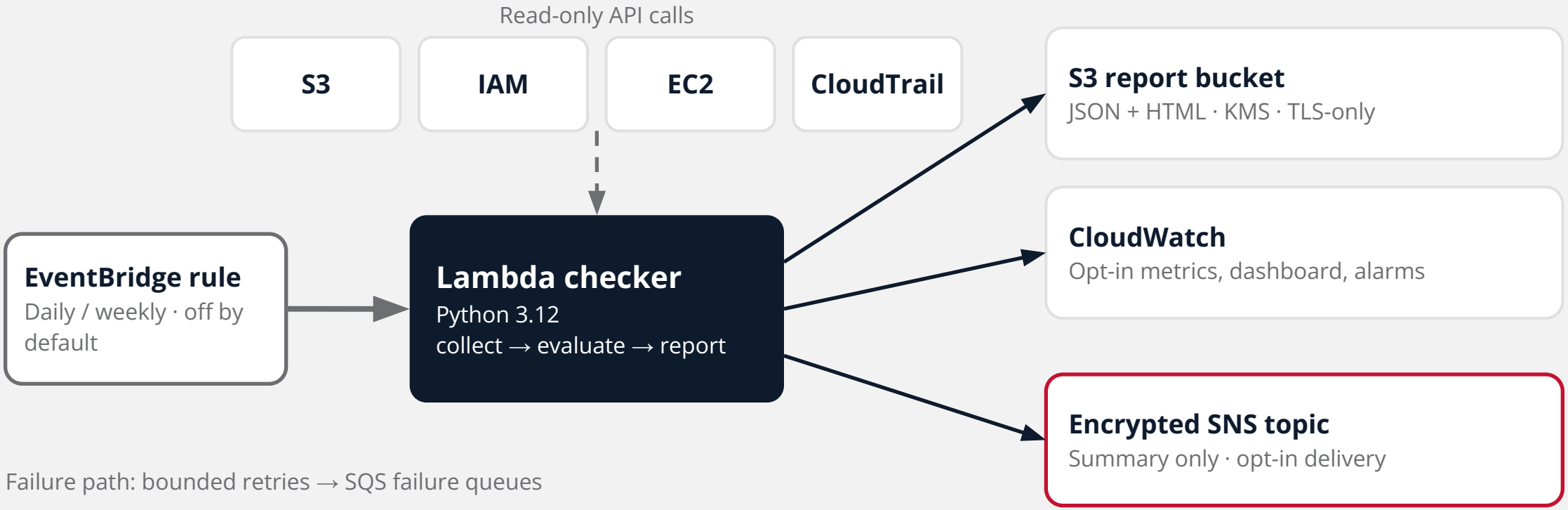
Make five technical controls repeatable and reviewable

Dimension	Manual review	Implemented checker
Frequency	When a reviewer runs it	**On demand; schedule configured**
Scope	Reviewer-selected resources	**Explicit account, regions and buckets**
Evidence	Reviewer notes and screenshots	**Structured findings + JSON / HTML**
Unknowns	May need follow-up	**UNKNOWN + incomplete coverage**
Triage	Reviewer interpretation	**Severity + evidence + next step**
Validation	Depends on review procedure	**Three fixtures and 88 tests**

Design comparison; no measured claims about production time savings or detection latency.

SOLUTION ARCHITECTURE

Read-only scanning, gated cloud delivery



Failure path: bounded retries → SQS failure queues

Monitoring alarms have no notification actions configured.

SAM deployment configuration is implemented; real AWS deployment has not been performed.

AWS SERVICES & INTEGRATION POINTS

Explicit scope and independently gated outputs

Service	Role	Scope / safety
EventBridge	Scheduled invocation	Daily / weekly; disabled by default
Lambda	Run five control groups	Python 3.12; offline mode by default
IAM + STS	Identity and permissions	Expected account; read-only scan APIs
S3 + KMS	Store JSON and HTML	Private bucket; explicit write opt-in
CloudWatch	Logs and optional monitoring	Three metrics; alarms have no actions
SNS + SQS	Summary / failure handling	SNS opt-in; separate failure queues

Data flow: **EventBridge → Lambda → AWS read APIs → gated S3 reports, SNS summary and metrics**

IMPLEMENTATION DESIGN · CORE LOGIC

Five controls, evidence-backed findings

1 Collect
run each check

2 Evaluate
status + severity

3 Store
JSON + HTML

4 Notify
summary only

5 Measure
opt-in metrics

Control	Baseline evaluated	Failure risk
S3 public access	Effective four BPA flags enabled	HIGH
S3 encryption	Default SSE-KMS or DSSE-KMS	MEDIUM
IAM MFA	Root + console users have MFA	CRITICAL / HIGH
EC2 ingress	No /0 access to ports 22 or 3389	HIGH
CloudTrail	Active, complete management events	HIGH

Pass rate = PASS / (PASS + FAIL). UNKNOWN and N/A stay separate; empty denominator = null.

IMPLEMENTATION DESIGN · ROBUSTNESS

Unknown evidence stays unknown

Error handling

- Access denied or service errors produce UNKNOWN
- Independent checks continue with available evidence
- Standard SDK retry: at most four total attempts
- Unexpected program errors fail explicitly
- Delivery failures raise; partial uploads are possible
- Optional alarms cover Lambda errors and unknowns

Security considerations

- Offline demo is the default execution mode
- STS validates the expected account before scanning
- S3 requests include the expected bucket owner
- Cloud reads, writes and notifications require opt-in
- No resource remediation or real email in this demo
- A technical baseline is not HIPAA certification

DEMO · INPUT → PROCESSING → OUTPUT

Three scenarios, one reproducible checker

1 · INPUT

```
Synthetic AWS responses
```

- Compliant: 6 PASS, 1 N/A
- Misconfigured: 6 FAIL, 1 N/A
- Incomplete: 5 PASS, 1 UNKNOWN, 1 N/A
- No cloud resources created

2 · PROCESSING

```
python -m medtech.cli
```

- Same scanner with boto3 Stubber responses
- Five controls; stable evidence and run IDs
- JSON, HTML and notification preview

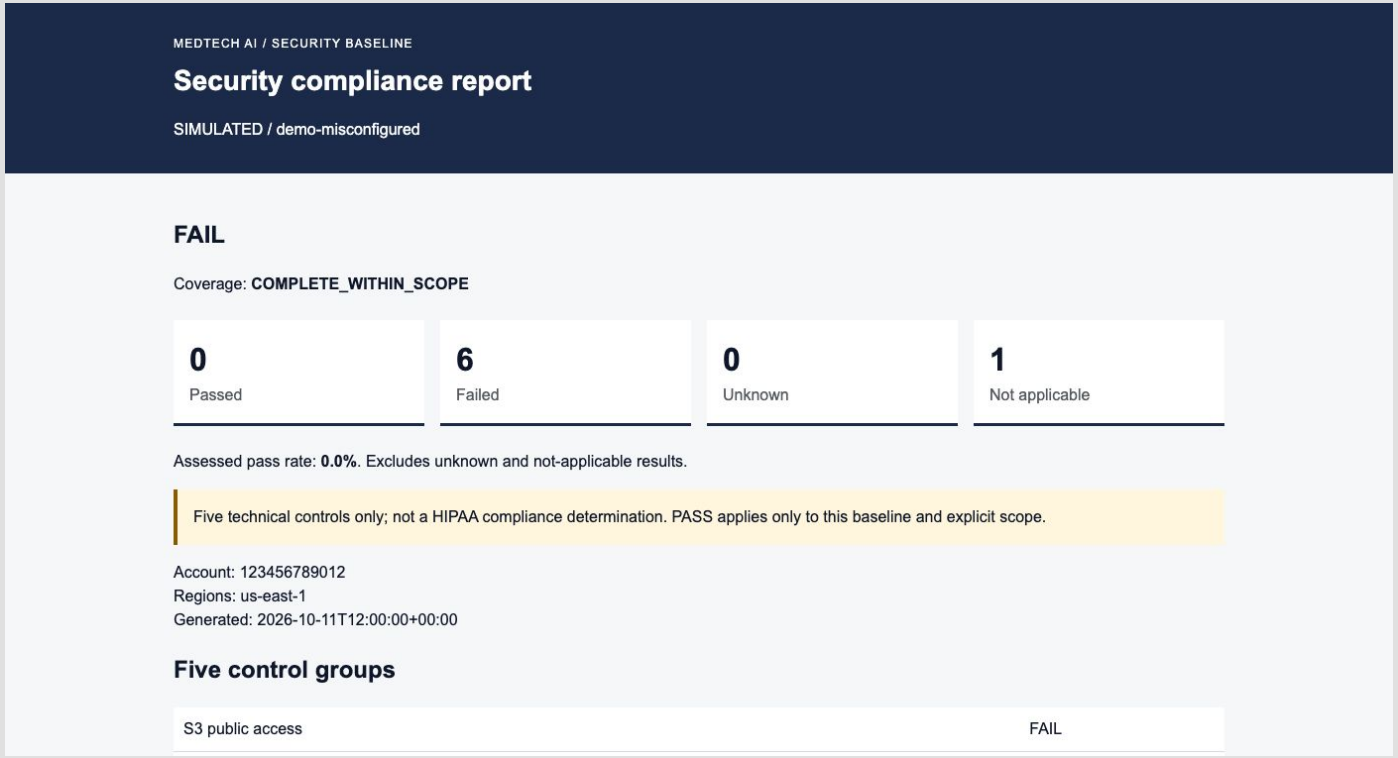
3 · OUTPUT

```
"status": "FAIL",
"counts": {
  "PASS": 0,
  "FAIL": 6,
  "UNKNOWN": 0,
  "NOT_APPLICABLE": 1 }
```


OPEN INTERACTIVE DEMO · Recorded offline output; no live AWS calls

DEMO · WHAT THE SECURITY TEAM RECEIVES

Prioritize the risk, inspect the evidence



MEDTECH AI / SECURITY BASELINE

Security compliance report

SIMULATED / demo-misconfigured

FAIL

Coverage: **COMPLETE_WITHIN_SCOPE**

0	6	0	1
Passed	Failed	Unknown	Not applicable

Assessed pass rate: **0.0%**. Excludes unknown and not-applicable results.

Five technical controls only; not a HIPAA compliance determination. PASS applies only to this baseline and explicit scope.

Account: 123456789012
Regions: us-east-1
Generated: 2026-10-11T12:00:00+00:00

Five control groups

S3 public access	FAIL

NOTIFICATION PREVIEW

```
MedTech baseline: FAIL
```

TOP FINDINGS

CRITICAL Root MFA not enabled

HIGH Console user lacks MFA

HIGH SSH / RDP open to a /0 CIDR

ROOT EVIDENCE (SIMULATED)

AccountMFAEnabled: 0

Validate context before remediation.

Actual offline HTML report. S3 delivery and SNS email were not performed.

VALIDATION & OPERATING LIMITS

Validation and estimated operational value

88	3	5	0
automated tests passed	reproducible demo scenarios	implemented control groups	real AWS deployments

Time savings (illustrative)

30 runs x (15 - 5) human minutes = 5 hours/month
66.7% less human time for these five checks.
$300 staff capacity at assumed $60/hour.
Human timing is assumed, not measured.

Cloud cost (illustrative)

~$0.02 base / ~$4.12 with optional monitoring.
30 daily runs, 256 MB Arm, assumed 30 sec/run.
Rounded-up budgets before credits and exclusions.
Live IAM, scheduling and email need a pilot.

Assumptions, rates and sources: docs/VALUE_AND_COST.md

FUTURE ENHANCEMENTS

A bounded path to production



Expand control coverage

- SageMaker network and storage settings
- KMS key policy and rotation review
- SSO and federated MFA enforcement
- CloudTrail data events and freshness



Improve operations

- Persistent deduplication and delivery recovery
- Schedule-aware missed-run detection
- Human review before any remediation



Run an authorized pilot

- Validate least privilege in an isolated account
- Measure scan time, quotas and real costs
- Add regions and accounts with explicit scope



SUMMARY

Five controls.
Evidence you can inspect.

Verified offline checks, clear findings and a deployable design.
Next step: an authorized cloud pilot.

Explore the demo